Case study by Chandana Vishnu Jayanth · vishnuatgit.github.io · jayanthvishnu9@gmail.com
Live demo: supplytrace-fkpq.onrender.com · Code: github.com/vishnuatgit/SupplyTrace

SupplyTrace

A modular pipeline that ingests raw XML invoices, validates them with deterministic rules and compiles standardized feature matrices, with an experimental ML risk score.

YEAR

2026

BUILT WITH

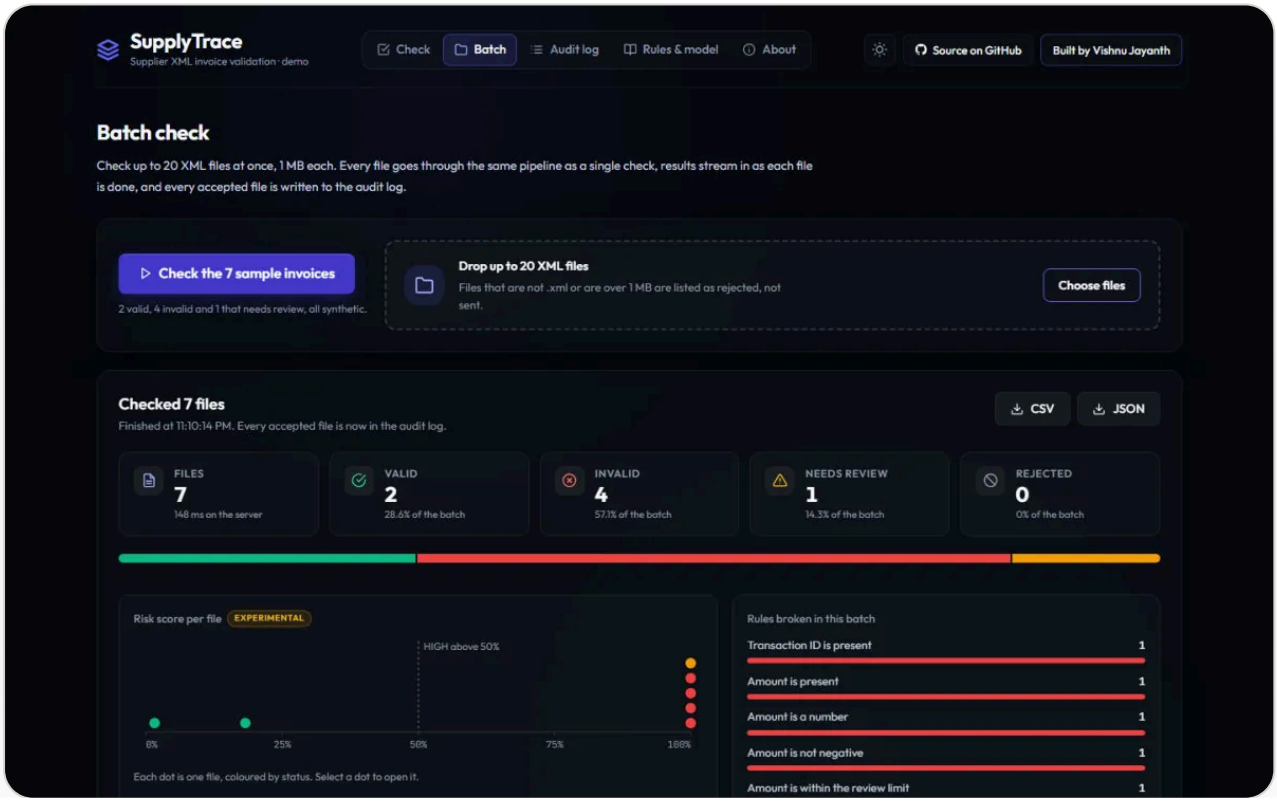
FastAPI · scikit-learn · Pandas

PROOF

- 163 tests · CI passing

SOURCE

github.com/vishnuatgit/SupplyTrace



(01) The problem

WHY IT EXISTS

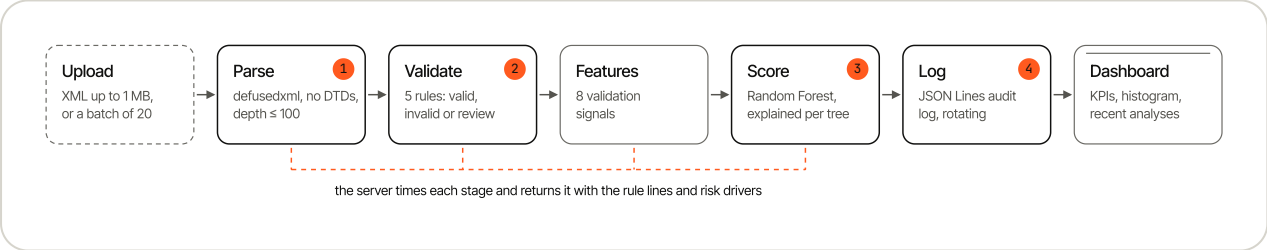
Bad invoice data rarely fails where it arrives. *It fails later,* several systems downstream.

By then it is hard to trace back to the file that caused it. SupplyTrace checks each file at the door: it labels every invoice valid, invalid or needs review with deterministic rules, points each rule at the line of the file behind it, and logs the result.

An experimental Random Forest adds a risk score trained on 400 synthetic invoices, with an explanation of what drove each prediction.

(02) How it works

FROM THE README



1 **Parse safely.** The upload is parsed in memory with `defusedxml` (no DTDs), files nested more than 100 levels deep are rejected, and uploads over 1 MB get a `413`. The XML is flattened into dot-notation keys, and a second `expat` pass records each element's line.

2 **Validate with rules.** Five deterministic rules decide the status: `VALID`, `INVALID` or `REQUIRES_REVIEW`. Every rule comes back as a checklist row with the line that shows it.

3 **Score the risk (experimental).** Eight validation signals go to a Random Forest trained on the synthetic batch; the score comes with the base rate plus one contribution per feature.

4 **Log it.** One JSON line per file goes to a rotating audit log, which also feeds the dashboard.

(03) Key decisions

5 CHOICES

01 The rules decide; the model only advises

The status always comes from five deterministic rules. The risk score is labelled experimental: it is trained on synthetic data and says nothing about real suppliers.

02 Treat every upload as hostile

`defusedxml` refuses DTDs, so there is no entity expansion or external entities; the 1 MB cap is enforced before the body is read; documents nested more than 100 levels deep are rejected.

03 Explanations that add up

The explanation follows each tree from its root to the file's leaf and credits every split's change in failure rate to the feature it tested (tree-path attribution). The base rate plus the contributions equals the score, and the tests check it.

04 One code path, an audit trail

A single check, a batch and a streamed batch all call the same `analyze_document()`, so a file gets the same answer every way (tests compare them). Every result is one line in a rotating JSON Lines audit log.

05 Evaluate against a rules-only baseline

The server trains a fresh model on 300 invoices and tests it on the other 100 next to a baseline that fails a file exactly when the rules do. At the 50% threshold the model makes the same call as the rules on every held-out file.

(04) Proof

TESTS · CI · STACK

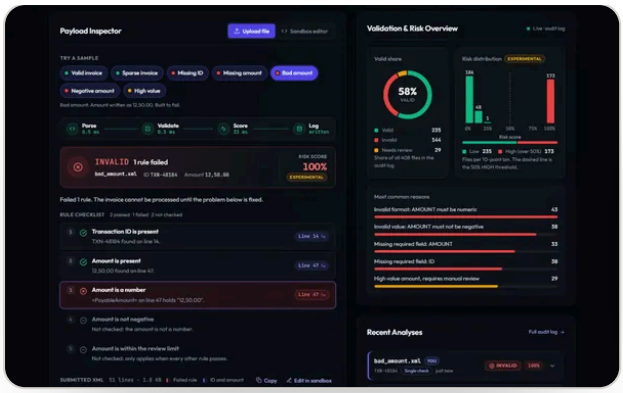
163	Passing	400
PYTEST TESTS, NO NETWORK	CI ON PYTHON 3.11 AND 3.12, WITH RUFF	SYNTHETIC INVOICES THE RISK MODEL TRAINS ON

The suite covers XML parsing and safety (DTDs, entity expansion, depth and size limits, parse-error positions), every validation rule and every example on the rules page, the risk explanation (it must add up to the score), the single, batch and streamed endpoints (including that they agree), the audit log and the model card's holdout metrics. CI runs ↗

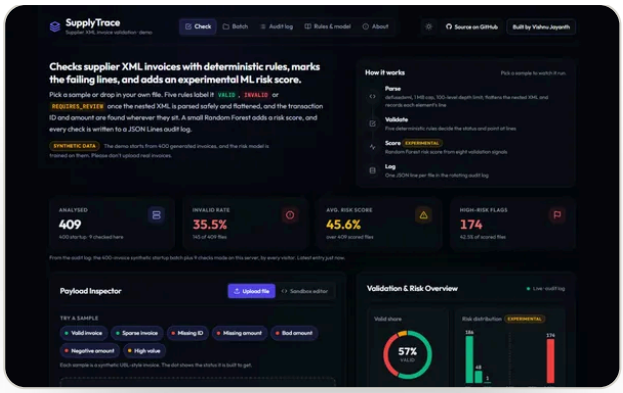
`Python 3.11+` `FastAPI` `Uvicorn` `defusedxml` `pandas` `NumPy` `scikit-learn` `pytest` `pytest-cov` `Ruff` `GitHub Actions`

(05) Screenshots

FROM THE REPOSITORY



A check: the verdict, the rule that failed and the line behind it.



The home page: the dashboard numbers come from the audit log.

(06) Limitations

HONESTLY

- **Synthetic training data.** The risk model is trained on synthetic invoices with simulated outcomes; real use would need outcome data, and the scores are not calibrated probabilities.
- **Five rules only:** no checks on line totals, tax, dates, currencies or duplicate invoices.
- **Flattening loses detail.** Repeated elements, such as several invoice lines, collapse to the last one, and XML attributes are ignored.
- **One shared audit log**, reset on every restart on the free host.
- **No saved model.** It is retrained at every startup, and there are no accounts or authentication.

NEXT CASE STUDY

ArchLens ↗

Scores any public GitHub repository from 0 to 100 across seven engineering dimensions, as a web app, a REST API and a CLI.